CA TRUST COLLAPSE BRIEF
Go Certificate Authority Block + eMudhra Revocation — 20 October 2026
==========

SITUATION

On 20 October 2026, the Go programming language team moved to block a certificate authority (CA) after discovering that eMudhra, an Indian CA, had issued certificates for Go's infrastructure domains without proper authorization.

The incident affects the broader Web PKI trust model and demonstrates how quickly trust can be revoked in the modern certificate ecosystem.

TECHNICAL DETAILS

Go's security team detected unauthorized certificate issuance for:
- proxy.golang.org
- sum.golang.org
- go.dev
- pkg.go.dev

The certificates were issued by eMudhra Limited (CA ID: eMudhra), which is a root CA trusted by major browsers and operating systems.

The unauthorized issuance violates CA/Browser Forum Baseline Requirements, specifically:
- Section 4.2: Subject Identity Verification
- Section 4.9: Certificate Revocation
- Section 4.10: CA Security Incident Response

GO'S RESPONSE
---
1. Certificate Transparency (CT) log monitoring detected the issuance.
2. Go team filed incident reports with affected CT log operators.
3. Go requested emergency revocation through the CA incident process.
4. Go implemented additional DNS-based protections (CAA records).
5. Go is considering removing eMudhra from Go's root store.

TIMELINE

T+0:00 CT log entry appears for unauthorized certificate.
T+0:12 Go's automated CT monitor detects anomaly.
T+0:30 Security team validates: no Go-issued CSR, no Go approval.
T+1:00 Emergency contacts at eMudhra notified.
T+2:00 Certificate revocation requested via CA/Browser Forum process.
T+4:00 Major browsers begin CRL updates.

T+6:00 Go implements DNS CAA records blocking non-Go CAs.
T+8:00 Public disclosure by Go security team.

Total time from detection to mitigation: 8 hours.

EMUDHRA CONTEXT
---
eMudhra Limited is an India-based CA with roots in multiple trust stores:
- Mozilla NSS (included)
- Apple System Trust (included)
- Microsoft Trusted Root (included)
- Chrome (via Mozilla inclusion)

eMudhra has faced prior controversy:
- 2022: Browser vendors flagged weak certificate practices.
- 2024: Multiple misissuance incidents reported.
- 2025: CA/Browser Forum audit flagged compliance gaps.

This incident is not isolated — it represents a pattern.

THE BROADER TRUST PROBLEM

The Web PKI relies on ~100 root CAs being trusted by every browser and
operating system. When one CA misbehaves:

1. DISCOVERY depends on CT log monitoring (not all CAs log to all CT logs).
2. REVOCATION is slow (CRL updates propagate over hours/days).
3. BLAST_RADIUS includes every domain the CA could have issued for.
4. ACCOUNTABILITY is diffuse (CA/Browser Forum enforcement is slow).

The fundamental issue: trust is binary. A CA either has root access to
your browser or it doesn't. There is no graduated trust model.

MITIGATIONS FOR ORGANIZATIONS
---
1. DNS CAA RECORDS
Set Certificate Authority Authorization records to explicitly list
which CAs may issue certificates for your domains.

Example:
yourdomain.com. IN CAA 0 issue "letsencrypt.org"
yourdomain.com. IN CAA 0 issuewild "letsencrypt.org"
yourdomain.com. IN CAA 0 iodef "mailto:security@yourdomain.com"

CAA records are checked by CAs before issuance (RFC 8657).

2. CERTIFICATE TRANSPARENCY MONITORING

Subscribe to CT log alerts for your domains. Free services:
- crt.sh (search + alerts)
- Google CT (monitoring API)
- Facebook CT (notification service)

3. CERTIFICATE PINNING (where applicable)
For mobile apps and critical services, implement certificate or
public key pinning. This bypasses the CA trust model entirely.

4. INTERNAL PKI FOR CRITICAL INFRASTRUCTURE
Don't rely on public CAs for internal services. Run your own
certificate authority with short-lived certificates.

5. DNS-LEVEL PROTECTIONS
- DANE/TLSA records (requires DNSSEC)
- HTTPS RSR (HTTP Response Strict Rebinding)

LESSONS FOR GO AND THE ECOSYSTEM
---
1. CT LOG MONITORING WORKS
The attack was detected in 12 minutes. CT logs are not just
transparency — they are detection infrastructure.

2. TRUST STORES NEED FASTER REVOCATION
When a CA is compromised, removing it from trust stores should take
hours, not weeks. Emergency revocation processes need improvement.

3. MULTI-CA STRATEGIES REDUCE RISK
Organizations should not rely on a single CA for all certificates.
Use multiple CAs with CAA records as a constraint.

4. AUTOMATED INCIDENT RESPONSE IS ESSENTIAL
Go's 12-minute detection and 8-hour mitigation is the gold standard.
Manual processes cannot compete with automated misissuance.

5. REGULATORY PRESSURE IS NOT ENOUGH
CA/Browser Forum baseline requirements are necessary but not
sufficient. Technical controls (CT, CAA, DANE) are the real defense.

FUTURE CONSIDERATIONS

- Short-lived certificates (hours, not days) reduce revocation needs.
- ACME Renewal Information (ARI) helps clients recover from misissuance.
- Certificate problem reports should be machine-readable and actionable.
- Post-quantum cryptography transition will require new trust models.

CLOSING

Trust revoked faster than disclosure.

The certificate is not the trust. The cryptographic proof is the trust.

Report: ERR.SYS Field Guide 002
Date: 20 October 2026
Source: Go Security Team, The Hacker News
Classification: TLP:CLEAR